

Contents

ms-pagos — Justificación del servicio y cobertura de requisitos	1
1. Misión del servicio	1
2. Requisitos funcionales que cubre	1
3. Requisitos no funcionales que cubre	1
4. Requisitos de seguridad que cubre (mapeo STRIDE)	2
5. Stack tecnológico y por qué cada tecnología	2
6. Delimitación: qué NO hace ms-pagos (IE9/IE10)	3
7. Diagramas que respaldan esta justificación	4

ms-pagos — Justificación del servicio y cobertura de requisitos

Caso caso06 — ViajaMejor (Reservas de viajes) · EP01 JVV0101

Este documento justifica la existencia de **ms-pagos** como microservicio independiente: qué requisitos del negocio cubre (funcionales, no funcionales y de seguridad), por qué está delimitado así (SRP), y qué tecnología AWS se usa para cada responsabilidad y **por qué**. Los diagramas que respaldan esta justificación están en `docs/diagramas/`.

1. Misión del servicio

ms-pagos procesa cobros y reembolsos contra la pasarela de pagos, mantiene la trazabilidad financiera y garantiza que ninguna operación se cobre ni pierda dos veces del caso caso06 (ViajaMejor).

Es el único servicio que toca instrumentos financieros y datos sensibles de tarjeta: se aísla por cumplimiento (PCI DSS), con tokenización, idempotencia estricta y auditoría completa. Ningún otro servicio puede verse comprometido por un incidente de pago, y viceversa.

2. Requisitos funcionales que cubre

RF	Requisito (de <code>00_PresentacionEmpresa.md</code>)	Qué hace ms-pagos al respecto	Evidencia
RF-05	Procesar el pago de reservas y emitir comprobantes	Ejecuta el cobro/reembolso contra la pasarela de forma idempotente y registra la operación financiera	diagrama de secuencia (cobro idempotente)

Por qué estos RF justifican un servicio aparte: Es el único servicio que toca instrumentos financieros y datos sensibles de tarjeta: se aísla por cumplimiento (PCI DSS), con tokenización, idempotencia estricta y auditoría completa. Ningún otro servicio puede verse comprometido por un incidente de pago, y viceversa.

3. Requisitos no funcionales que cubre

RNF	Criterio	Cómo lo cumple ms-pagos	Decisión técnica
RNF-04 (Seguridad)	Cifrado de datos de pago y personales, autenticación y control de acceso por rol	JWT por rol, cifrado en tránsito (TLS) y reposo (KMS), auditoría de acciones	Cognito + KMS + Secrets Manager + CloudTrail

RNF	Criterio	Cómo lo cumple ms-pagos	Decisión técnica
RNF-06 (Consistencia)	Las reservas deben sobrevivir a fallas; el pago debe ser atómico con la confirmación de la reserva	Escritura persistida antes de confirmar; eventos por cola con DLQ ante fallas	Aurora transaccional + SQS persistido + idempotencia
RNF-01 (Escala-bilidad)	Soportar picos de búsqueda en temporada alta escalando el buscador de forma independiente	Auto scaling independiente de este servicio (2→8 tareas Fargate según carga)	ECS Fargate + alarmas de CloudWatch: solo este componente escala en el pico

Justificación SRP (IE9): ms-pagos tiene **una sola razón de cambio**: la integración con la pasarela, los medios de pago y la normativa financiera. Si mañana cambia esa regla, **ningún otro servicio se modifica**.

4. Requisitos de seguridad que cubre (mapeo STRIDE)

Amenaza	Escenario en este servicio	Contramedida
Spoofing	Suplantar al pagador o al comercio	JWT + confirmación del titular en la pasarela; doble verificación de identidad
Tampering	Alterar el monto o el estado de un cobro	Monto firmado en la orden origen; el cobro se valida contra la orden y el webhook firmado de la pasarela
Repudiation	Negar un cobro o reembolso	Registro financiero inmutable (trail completo) + webhooks firmados por la pasarela + CloudTrail
Information disclosure	Fuga de datos de tarjeta	Tokenización en la pasarela: el PAN nunca toca este servicio; cifrado KMS at-rest
Denial of service	Saturar los cobros en hora punta	Cola SQS que encola cobros + reintentos con backoff; la pasarela nunca recibe el pico directo
Elevation of privilege	Ejecutar reembolsos sin autorización	Rol financiero separado en el JWT; reembolso exige doble autorización y queda auditado

5. Stack tecnológico y por qué cada tecnología

5.1 Stack de la aplicación

Tecnología	Para qué se usa en ms-pagos
Java 21 + Spring Boot 3.3	Framework estándar de la asignatura: implementa la API REST, la lógica de negocio y el acceso a datos del servicio
Spring Data JPA	Persistencia de las entidades del dominio en la base de datos propia (repositorios por entidad)
Bean Validation	Validación de los payloads de entrada antes de procesar (jakarta.validation)
springdoc-openapi	Documentación viva del contrato REST (Swagger UI / ReDoc) para consumidores y equipo
Docker + Docker Compose	Empaquetado reproducible; la misma imagen corre en local y en ECS Fargate
JUnit 5 + Mockito + MockMvc	Pruebas unitarias y de contrato HTTP (cobertura 100 % LINE con JaCoCo)
Cucumber (BDD)	Escenarios en español alineados a los endpoints, ejecutados contra el servidor real

5.2 Stack AWS y justificación de cada servicio

Servicio AWS	Rol en ms-pagos	Por qué se eligió
Amazon SQS (+ DLQ)	Cola de cobros con reintentos	El pico nunca golpea directo a la pasarela; nada se pierde (RNF de consistencia)
Amazon Aurora Serverless	BD financiera propia con trail completo	Auditoría y atomicidad del registro financiero (STRIDE-R)
AWS Lambda	Procesa el webhook de la pasarela	Carga intermitente: serverless escala a cero entre cobros
AWS KMS + Secrets Manager	Cifrado at-rest y secretos de la pasarela	Cumplimiento PCI: sin PAN almacenado, secretos rotados (RNF de seguridad)
Amazon EventBridge	Publica pago.confirmado / pago.rechazado	El paso siguiente del proceso se desacopla del cobro
CloudWatch + X-Ray + CloudTrail	Monitoreo y auditoría financiera	Toda operación de dinero queda trazada y auditada (IE8)

5.3 Patrones aplicados (IE5)

Patrón	Dónde
API Gateway	Entrada única con JWT y throttling
Circuit Breaker	Resilience4j hacia la pasarela con fallback controlado
Cola de mensajes (SQS + DLQ)	Encola cobros y reintenta con backoff sin perder operaciones
Idempotencia	Clave de idempotencia por operación: nunca se cobra dos veces

6. Delimitación: qué NO hace ms-pagos (IE9/IE10)

No hace	Lo hace	Por qué
usuarios	ms-usuarios	razones de cambio distintas: la autenticación se centraliza aquí, pero el negocio de cada dominio queda en su servicio

No hace	Lo hace	Por qué
búsqueda	ms-busqueda	razones de cambio distintas: el catálogo consulta y publica; las operaciones de negocio las orquesta el servicio transaccional
reservas	ms-reservas	razones de cambio distintas: la operación se orquesta aquí, pero cada colaborador es autónomo
integraciones	ms-integraciones	razones de cambio distintas: el seguimiento vive aquí, pero la operación que lo origina vive en el servicio central
fidelización	ms-fidelizacion	razones de cambio distintas: la operación se orquesta aquí, pero cada colaborador es autónomo

7. Diagramas que respaldan esta justificación

```
docs/diagramas/
├─ c4/
│   ├── C4-1-Contexto    el servicio, sus actores y sus vecinos
│   ├── C4-2-Contenedor  la API, la BD propia y los componentes del dominio
│   └─ C4-3-Componentes  validador/service, clientes, publicador, repos
├─ secuencia/
│   └─ Secuencia-Pago    cobro idempotente
└─ infraestructura/
    └─ Infra-AWS         despliegue solo de este servicio, con iconos oficiales AWS
```